

Practical 2: Improper Server-Side Validation in Checkout Process

Objective

To evaluate whether the web application's checkout process properly validates payment-related values on the server side and prevents unauthorized modification of transaction data.

Tools Used

- Burp Suite
- Mozilla Firefox
- Internshala Ethical Hacking Practice Lab

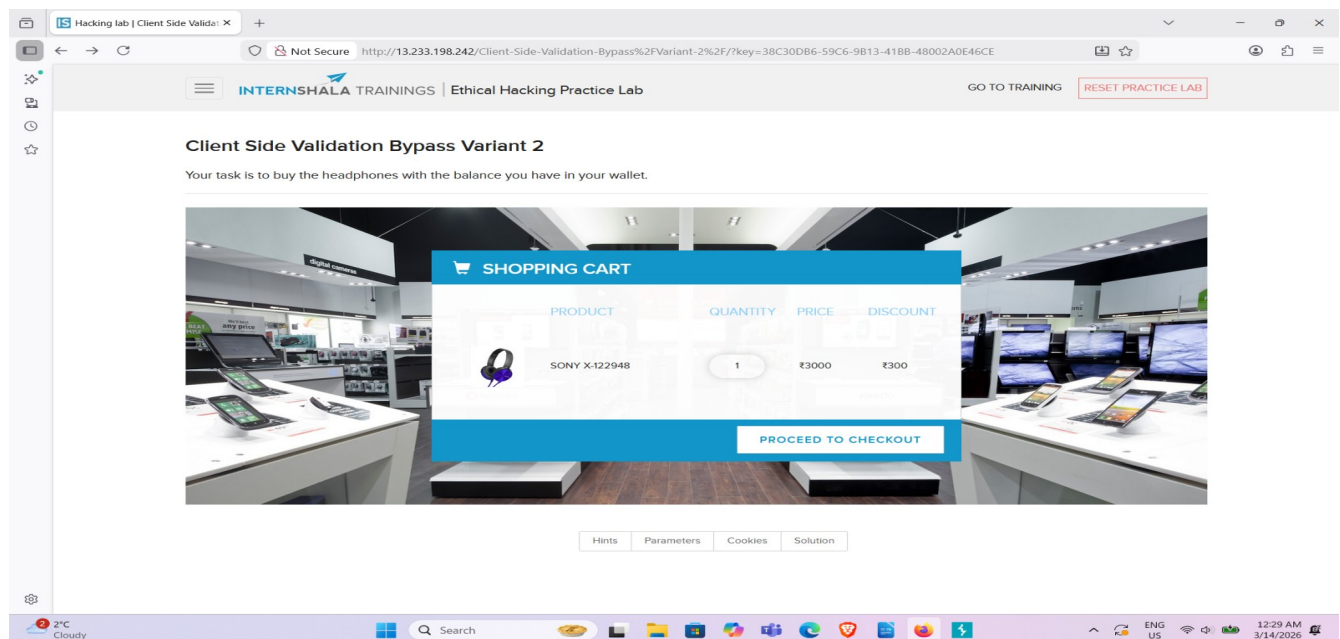
Target Application

The assessment was conducted against the checkout functionality of a training e-commerce application provided within the ethical hacking lab environment.

Methodology

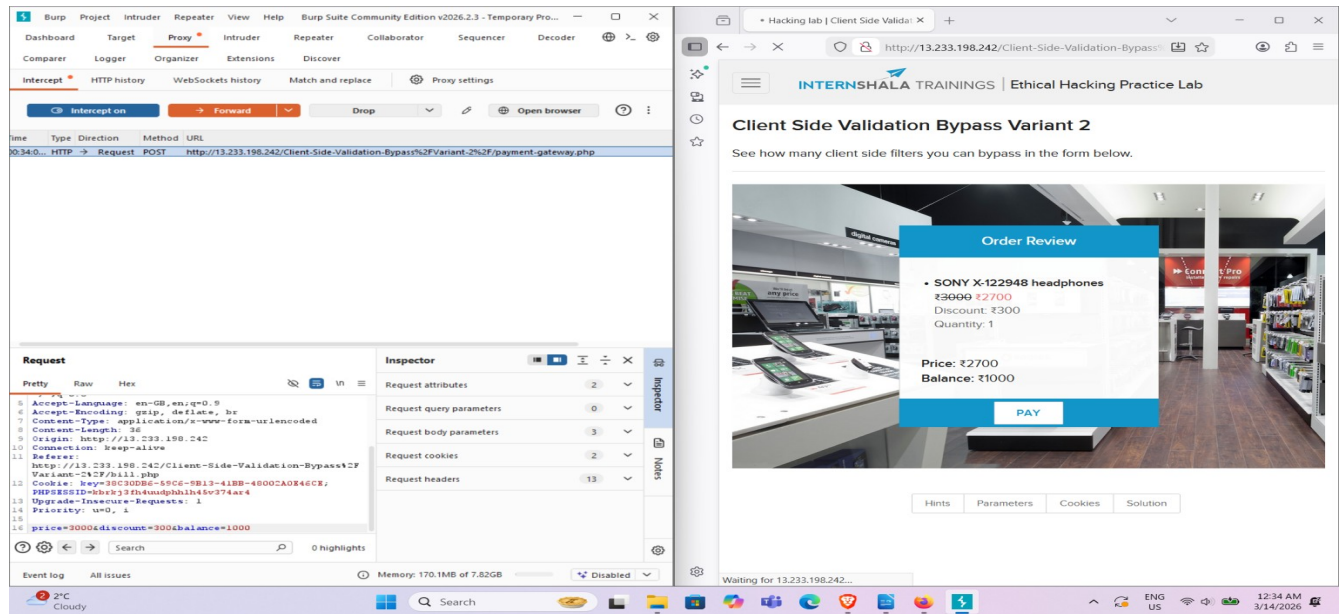
Step 1: Checkout Session Analysis

A product was selected and added to the shopping cart. The checkout process was initiated to observe how pricing and payment information were handled by the application.



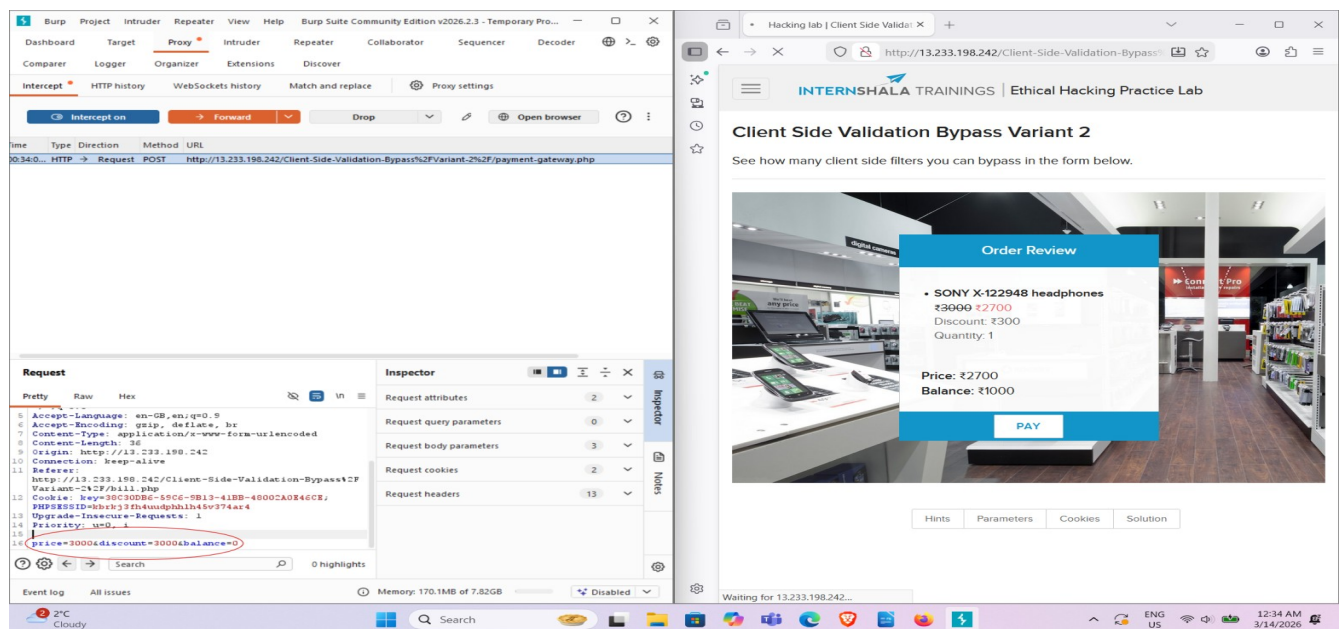
Step 2: Intercepting the Payment Request

Burp Suite was configured as a proxy and request interception was enabled. The checkout request containing pricing information and discount-related parameters was captured for analysis.



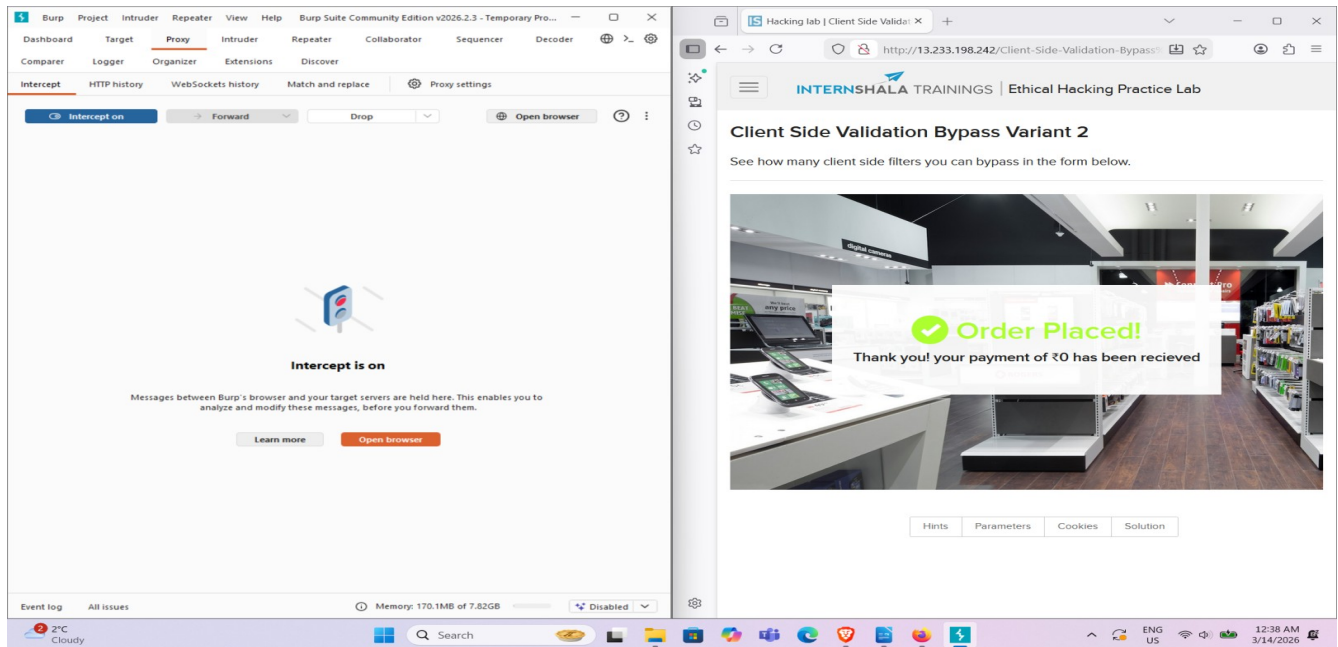
Step 3: Request Manipulation

The intercepted request was reviewed to identify parameters associated with the transaction amount. The request was modified to test whether the server independently verified the payment value before processing the order.



Step 4: Validation of Application Behavior

The modified request was forwarded to the server and the resulting application behavior was observed. The order workflow continued despite the altered transaction data, demonstrating insufficient server-side validation.



Result

The application processed an order without adequately validating transaction-related values on the server side. This indicates that critical business logic relied on client-controlled data, which could be modified during transmission.

Security Impact

Insufficient server-side validation within a checkout workflow can lead to business logic vulnerabilities, including unauthorized discounts, incorrect transaction values, or financial losses. Sensitive values such as pricing, discounts, and payment amounts should always be recalculated and validated on the server.

Recommended Mitigations

- Perform all price calculations on the server side.
- Never trust client-supplied payment values.
- Validate transaction data before order confirmation.
- Implement integrity checks for sensitive parameters.
- Log and monitor suspicious transaction activity.

Learning Outcome

This practical exercise improved understanding of business logic vulnerabilities and highlighted the importance of server-side validation for protecting critical transaction processes.